

PRD – SIM Swap & Transaction Fraud Risk Analytics (SecureBank Prototype)

Academic Year: 2025–26 | Dept. of CSE, GEC Haveri

1. Problem

Banks lean on SMS OTP for login, password reset, and transaction approval. In a SIM-swap attack, the attacker moves the victim's number to a new SIM and intercepts every OTP that follows – logins, resets, and transfers happen before anyone notices. Telecom and banking systems don't share signals in real time, so there's no single place that scores "is this SIM change + this login + this transfer, together, suspicious."

2. Goal (Phase 1 scope)

Ship a working prototype that ingests SIM and transaction events, scores them with a hybrid rules + ML engine, returns one of **ALLOW** / **STEP_UP** / **BLOCK**, persists everything, raises alerts, and shows it all on an analyst dashboard – using synthetic traffic, not real bank/telecom data.

3. Non-goals

- Real telecom carrier integration (webhook is simulated in Phase 1).
- Production-grade security hardening, PCI/regulatory compliance.
- Real SMS delivery in production volume (a sandbox provider is enough).

4. Users

User	Needs
Analyst	Live dashboard of alerts/events, clear reasons, can review risky events
Customer (simulated)	Triggers login/transaction/SIM-change events, completes OTP step-up
Admin	User management, system health, agent heartbeat status

5. Core Features (functional requirements)

1. **User registration/login** with JWT-based sessions.
2. **Transaction risk evaluation** — amount, location, device, login behavior → risk score.
3. **SIM-swap detection** — SIM-change frequency, time-since-change, device change.

4. **Rule-based scoring** — explainable, human-readable reasons per triggered rule.
5. **ML scoring** — logistic regression on engineered features → fraud probability.
6. **Hybrid decision engine** — merges rule score + ML probability → ALLOW / STEP_UP / BLOCK.
7. **OTP step-up** — generate, verify, expire OTPs for medium-risk events.
8. **Alerting** — persisted alert records + SMS/email notification on suspicious activity.
9. **Analyst dashboard** — recent transactions, SIM events, alerts, risk scores, agent status.
10. **Database persistence** — users, transactions, SIM events, OTPs, alerts, audit logs.
11. **REST API layer** — all modules talk over documented endpoints.
12. **Synthetic traffic simulator** — demo/monitoring agents generate realistic event streams.

6. Non-functional requirements

Security, reliability, performance (near real-time scoring), scalability, availability, maintainability, usability, transparency (every decision has a reason string), fault tolerance (system keeps scoring even if SMS/email is down), portability, data integrity.

7. Success criteria for Phase 1 demo

- End-to-end flow works: event in → risk scored → decision returned → row persisted → alert raised (if applicable) → dashboard reflects it within seconds.
- Every BLOCK/STEP_UP decision shows at least one human-readable reason.
- OTP step-up flow can be completed by a simulated customer and unlocks the transaction.
- Dashboard shows agent heartbeat (online/stale) for at least one synthetic traffic agent.

8. Risk classification policy

Risk score	Decision	Action
Low	ALLOW	Proceed normally
Medium	STEP_UP	Require OTP verification
High	BLOCK	Reject, raise alert immediately

Exact thresholds live in `backend/risk_engine/config.py`
 — tune during testing, document any
 change in `memory.md`.

9. Out-of-scope questions to resolve as a team before coding

- SQLite (report's stated prototype DB) vs MySQL (report's stated software requirement) —

decision: SQLite for Phase 1, see TECH_STACK.md
§Decision Log.

- Which SMS/email provider sandbox to use (see TECH_STACK.md – API keys).